

CONFIDENTIAL



# PHISHING DETECTION & AWARENESS REPORT

Case Study: Fake MetaMask Phishing Email

## REPORT DETAILS

|                 |                                          |
|-----------------|------------------------------------------|
| Organization:   | Future Interns                           |
| Prepared by:    | Prasad Sarkate                           |
| Role:           | SOC Analyst & Security Awareness Trainer |
| Date:           | 24 April 2026                            |
| Classification: | CRITICAL - PHISHING                      |

# TABLE OF CONTENTS

|    |                                                 |        |
|----|-------------------------------------------------|--------|
| 01 | Executive Summary                               | Pg 3   |
| 02 | Technical Deep-Dive Analysis                    | Pg 4   |
| 03 | Risk Classification & Business Impact           | Pg 5   |
| 04 | Email Evidence Gallery                          | Pg 6-7 |
| 05 | User Awareness Guide — Spot a Fake in 5 Seconds | Pg 8   |
| 06 | The Do's and Don'ts for Employees               | Pg 9   |
| 07 | Incident Response Checklist & Conclusion        | Pg 10  |

## REPORT AT A GLANCE

| SCL Score | Threat Level | Red Flags Found | Domain Mismatch |
|-----------|--------------|-----------------|-----------------|
| 9 / 10    | CRITICAL     | 8               | YES             |

## 01 EXECUTIVE SUMMARY

Phishing remains the single most prevalent and damaging cyber-attack vector facing organizations globally. According to industry threat intelligence, over 90% of successful data breaches begin with a phishing email. These attacks exploit human psychology — fear, urgency, and authority — rather than technical vulnerabilities, making them extraordinarily difficult to prevent through technology alone.

This report presents a detailed forensic analysis of a live phishing email impersonating **MetaMask**, a widely-used cryptocurrency wallet application. The email was crafted to induce panic in recipients by falsely claiming their digital wallets had been suspended, threatening permanent loss of cryptocurrency assets unless immediate action was taken via a malicious link.

**WARNING** This phishing attempt was classified as **CRITICAL** due to its financial targeting, domain spoofing, and use of fear-based manipulation tactics.

### Why Phishing Is a Major Business Threat

**Financial Loss:** Phishing attacks targeting cryptocurrency users aim to drain digital wallets instantly and irreversibly. For businesses, Business Email Compromise (BEC) scams cost organizations billions annually.

**Credential Theft:** Fake login portals harvest usernames, passwords, and seed phrases. Stolen credentials are used for account takeover, lateral movement, and data exfiltration.

**Reputational Damage:** A successful phishing attack can expose customer data, erode brand trust, and result in regulatory penalties under GDPR, DPDP Act, and similar frameworks.

**Operational Disruption:** Ransomware — often delivered via phishing — can halt business operations entirely, costing organizations millions in recovery costs and lost productivity.

**Supply Chain Risk:** Attackers increasingly target employees to gain a foothold for attacking the organization's clients, partners, or cloud infrastructure.

Security awareness training — supported by technical controls and clear incident-response procedures — is the most effective countermeasure. This report serves as both a technical reference for the security team and an awareness resource for all staff at Future Interns.

02

TECHNICAL DEEP-DIVE ANALYSIS

2.1 Email Header Forensics

The email header is the digital fingerprint of any email. Examining it reveals the true origin, routing path, and authentication results — all of which expose the deception in this phishing attempt.

|                  |                                          |                                                   |
|------------------|------------------------------------------|---------------------------------------------------|
| Message-ID       | 0E9E3B42...@sb1ostlandet.no              | Domain is sb1ostlandet.no — NOT metamask.io       |
| Displayed Sender | MetaMask                                 | RED FLAG: Display name spoofed                    |
| Actual Domain    | sb1ostlandet.no (Norwegian savings bank) | RED FLAG: Unrelated to MetaMask                   |
| Return-Path      | epost.sparebanken-hedmark.no.anpdm.com   | RED FLAG: Third-party mailer, not MetaMask        |
| SPF              | PASS — IP Unknown                        | Passes for sb1ostlandet.no, NOT metamask.io       |
| DKIM             | PASS — Domain Unknown                    | Signed by sb1ostlandet.no, NOT metamask.io        |
| DMARC            | PASS                                     | DMARC passes for sender domain, not claimed brand |
| SCL (Spam Score) | 9 out of 10                              | CRITICAL — Near-certain spam/phishing             |
| Delivery Delay   | 101 seconds                              | Typical of bulk mail systems                      |

2.2 Why SCL 9 Is a Critical Red Flag

Microsoft Exchange assigns a **Spam Confidence Level (SCL)** score from -1 to 9. A score of **9 indicates near-certainty that the message is spam or malicious**. SCL 9 emails are automatically routed to Junk in most corporate environments. The fact that this email carried SCL 9 means Microsoft's own filters identified it as highly suspicious, highlighting the importance of layered defenses and human vigilance.

|             |                                            |          |
|-------------|--------------------------------------------|----------|
| SCL -1 to 0 | Not spam — trusted sender or internal mail | SAFE     |
| SCL 1 to 4  | Unlikely spam — delivered to inbox         | LOW      |
| SCL 5 to 6  | Suspected spam — delivered to Junk folder  | MEDIUM   |
| SCL 7 to 8  | Probable spam — quarantined or junked      | HIGH     |
| SCL 9       | Definite spam / phishing — THIS EMAIL      | CRITICAL |

2.3 Domain Mismatch & Malicious URL

Authentication protocols (SPF, DKIM, DMARC) verify that an email was sent by a legitimate mail server for a domain — **but they do NOT verify that the domain matches the claimed brand**. The attacker sent email from **sb1ostlandet.no** (a Norwegian savings bank). All auth checks passed — for that domain. But the email claimed to be from **MetaMask**. The 'Press Here to Update' button linked to **tr2.epost.sb1ostlandet.no** — a heavily obfuscated redirect URL designed to harvest MetaMask seed phrases.

|              |                                                                                 |
|--------------|---------------------------------------------------------------------------------|
| Observed URL | tr2.epost.sb1ostlandet.no/x1exEpKh4Q1i491fEvFn7cpmIS49vxIEE2FGNy...             |
| Threat Type  | Credential Harvesting / Wallet Seed Phrase Theft                                |
| Obfuscation  | Long randomized path to evade URL scanners; hosted on legitimate-looking domain |
| Risk         | Clicking leads to fake MetaMask portal requesting Secret Recovery Phrase        |

03

RISK CLASSIFICATION & BUSINESS IMPACT

THREAT CLASSIFICATION

CRITICAL  
PHISHING

HIGH CONFIDENCE

Classification Justification

|                            |                                                                                              |
|----------------------------|----------------------------------------------------------------------------------------------|
| Targeting Methodology      | Cryptocurrency wallet users — high-value targets with direct access to liquid digital assets |
| Attack Vector              | Email-based social engineering with embedded malicious hyperlink                             |
| Impersonation Type         | Brand impersonation of MetaMask, a widely trusted and recognized crypto wallet               |
| Technical Sophistication   | Domain spoofing with legitimate auth pass-through; obfuscated tracking URL                   |
| Psychological Manipulation | Extreme urgency (deadline), fear of permanent financial loss, authority impersonation        |
| Potential for Mass Harm    | Bulk email campaign structure (anpdm.com mailer) — designed to reach thousands               |
| Data at Risk               | Cryptocurrency wallet seed phrases, private keys, account credentials                        |
| Recovery Potential         | NONE — cryptocurrency transactions are irreversible once processed                           |

Potential Business Impact

| Direct Financial Loss  | Holdings drained via stolen seed phrases. Average crypto phishing loss exceeds \$10,000 per victim.  | CRITICAL |
|------------------------|------------------------------------------------------------------------------------------------------|----------|
| Credential Theft       | Stolen credentials enable access to corporate VPN, cloud services, or internal systems.              | HIGH     |
| Data Breach            | Compromised accounts expose corporate data, client information, or intellectual property.            | HIGH     |
| Regulatory Penalties   | Under India's DPDP Act 2023, inadequate security awareness training could attract significant fines. | MEDIUM   |
| Reputational Damage    | A successful phishing attack erodes client trust and brand reputation in the market.                 | HIGH     |
| Operational Disruption | Ransomware deployed via stolen credentials can halt all operations for days or weeks.                | CRITICAL |

04

## EMAIL EVIDENCE GALLERY

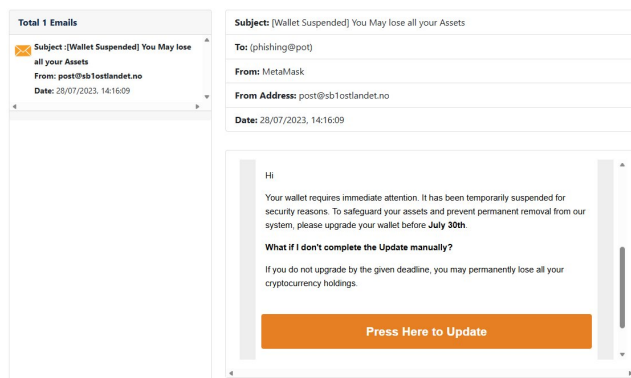
The following screenshots were captured during forensic analysis of the phishing email. Each image is annotated with key observations relevant to the investigation.

Figure 1: Email Header Analysis Report

|             |                                                            |
|-------------|------------------------------------------------------------|
| MessageId   | 0E9E3B42EF2E4A5F98904ADBFI399C6A@sb1ostlandet.no           |
| Created at: | 7/28/2023, 7:46:09 PM GMT+5:30 ( Delivered after 101 sec ) |
| From:       | "MetaMask" <post@sb1ostlandet.no>                          |
| To:         | phishing@pot                                               |
| Subject:    | [Wallet Suspended] You May lose all your Assets            |
| SPF:        | pass with IP Unknown!<br><a href="#">Learn more</a>        |
| DKIM:       | pass with domain Unknown!<br><a href="#">Learn more</a>    |
| DMARC:      | pass<br><a href="#">Learn more</a>                         |

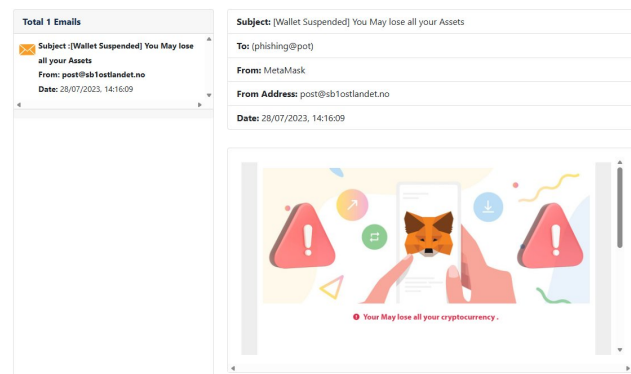
Header analysis revealing MessageID origin from sb1ostlandet.no (NOT MetaMask), SPF/DKIM/DMARC passing for the wrong domain, and delivery metadata.

Figure 2: Phishing Email Body



Fear-based language, July 30th deadline, and the malicious 'Press Here to Update' button.

Figure 3: Email Banner Image



Stolen MetaMask branding assets with warning triangles to reinforce fear and urgency.

Figure 4: Malicious URL in Status Bar



Figure 5: Raw Email Headers & Server Hop Analysis

| #       | Delay | From *                                              | To *                                | Protocol | Time received                  |
|---------|-------|-----------------------------------------------------|-------------------------------------|----------|--------------------------------|
| 101 sec |       | DM6NAM12FT092.eop-nam12.prod.protection.outlook.com | DM6PR21CA0019.outlook.office365.com |          | 7/28/2023, 7:47:50 PM GMT+5:30 |

[ANALYZE ANOTHER HEADER](#)

[SHOW RAW HEADER](#)

```

Received: from S30PR19W5461.namprd19.prod.outlook.com (::1) by
HWBP19WB0312.namprd19.prod.outlook.com with HTTPS; Fri, 28 Jul 2023 14:17:51
+0000
Received: from DM6PR21CA0019.namprd21.prod.outlook.com (2603:1006:5:174:129)
by S30PR19W5461.namprd19.prod.outlook.com (2603:1006:a83:3e3::5) with
Microsoft SMTP Server (version=TLS1_2,
cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.28.6631.29; Fri, 28 Jul
2023 14:17:50 +0000
Received: from DM6NAM12FT092.eop-nam12.prod.protection.outlook.com
(2603:1006:5:174:cafe::a3) by DM6PR21CA0019.outlook.office365.com
(2603:1006:5:174:129) with Microsoft SMTP Server (version=TLS1_2,
cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.28.6652.5 via Frontend
Transport; Fri, 28 Jul 2023 14:17:50 +0000
Authentication-Results: spf=pass (sender IP is 91.227.208.157)
smtp.mailfrom=epost.sparebanken-hedmark.no; dkim=pass (signature
was verified) header.d=sbiostlandet.no; dmarc=pass action=none
header.from=sbiostlandet.no; compauth=pass reason=100
Received-SPF: Pass (protection.outlook.com: domain of
  
```

SMTP routing through Microsoft EOP. SPF sender IP: 91.227.208.157 — not a MetaMask server.

05

**USER AWARENESS GUIDE — SPOT A FAKE IN 5 SECONDS**

**NOTE** This section is for non-technical staff. No IT knowledge required — just five quick checks before you click anything.

**1****STEP 1: CHECK THE SENDER'S EMAIL ADDRESS**

The email says 'From: MetaMask' — but look at the actual address in angle brackets: — a Norwegian bank, NOT MetaMask. Legitimate companies send from their own domain (e.g., @metamask.io).

***TIP:** Real MetaMask emails come from @metamask.io — anything else is fake.*

**2****STEP 2: SMELL-TEST THE URGENCY**

'Act before July 30th or lose everything!' is a manipulation tactic. Real companies give you time and do not threaten permanent data loss via email. When you feel panicked — slow down. That panic is the attack working.

***TIP:** If it screams emergency, treat it as suspicious until verified.*

**3****STEP 3: HOVER OVER LINKS BEFORE CLICKING**

Hover your mouse over a button (on desktop) or long-press (on mobile) to see the real URL. The 'Press Here to Update' button pointed to tr2.epost.sb1ostlandet.no — NOT metamask.io.

***TIP:** The displayed text and real URL must match the company's official domain.*

**4****STEP 4: LOOK FOR GENERIC GREETINGS**

This email just said 'Hi' — no name, no account number. Your real MetaMask account knows your name. Generic greetings like 'Dear Customer' or 'Hi' signal mass phishing campaigns.

***TIP:** Generic greetings are a clear warning sign.*

**5****STEP 5: WHEN IN DOUBT — DO NOT CLICK. REPORT IT.**

You do not need to be 100% sure an email is phishing to report it. If something feels wrong, forward it to IT Security immediately. It takes 3 seconds to report. It takes months to recover from a successful attack.

***TIP:** Report to IT/Security team. Never just check a suspicious link.*



06

## THE DO'S AND DON'TS FOR EMPLOYEES

## DO'S

Verify the sender's actual email domain — not just the display name.

Hover over every link before clicking to see the real destination URL.

Report suspicious emails to IT Security immediately — even if unsure.

Access services directly by typing the official URL in your browser.

Contact the sender via a known phone number if a request seems unusual.

Complete regular phishing awareness training provided by the organization.

Enable Multi-Factor Authentication (MFA) on all critical accounts.

Use a password manager to avoid reusing passwords across services.

Check for spelling errors or design inconsistencies in emails.

Mark and delete confirmed phishing emails after reporting them.

## DON'TS

Do NOT click links asking you to 'verify', 'update', or 'confirm' credentials.

Do NOT open attachments from unexpected or unrecognized senders.

Do NOT enter your password or seed phrase on any website reached via email.

Do NOT be pressured by urgency or threatening language — take your time.

Do NOT assume SPF/DKIM/DMARC 'pass' means the email is legitimate.

Do NOT reply to suspicious emails — this confirms your address is active.

Do NOT use personal devices or unsecured Wi-Fi to access corporate systems.

Do NOT share OTPs with anyone — even IT support will never ask for them.

Do NOT ignore security warnings from your email client or browser.

Do NOT attempt to 'investigate' phishing links yourself — report to IT.

07

## INCIDENT RESPONSE CHECKLIST

If you received a phishing email — or worse, clicked a link or entered credentials — follow this checklist immediately:

### IMMEDIATE — Within 5 Minutes

- ☐ Do NOT click any more links in the email.
- ☐ If you clicked a link: disconnect your device from the internet immediately.
- ☐ If you entered credentials: notify IT Security IMMEDIATELY — do not wait.
- ☐ Do NOT delete the email — it is forensic evidence.

### SHORT-TERM — Within 1 Hour

- ☐ Forward the phishing email (as attachment) to your IT/Security team.
- ☐ Change your password for any service mentioned in the email — from a CLEAN device.
- ☐ Revoke active sessions for affected accounts if the platform allows it.
- ☐ Enable MFA immediately on any account you changed the password for.

### FOLLOW-UP — Within 24 Hours

- ☐ Complete an incident report form as directed by IT Security.
- ☐ Scan the affected device with approved antivirus/EDR tools.
- ☐ Monitor your accounts for unauthorized activity for 30 days.
- ☐ Attend a security debrief if requested by the security team.

08

## CONCLUSION & RECOMMENDATIONS

The MetaMask phishing email analyzed in this report represents a sophisticated, high-confidence phishing attack targeting cryptocurrency holders. Despite passing standard email authentication checks (SPF/DKIM/DMARC), the email displayed an SCL score of 9, a mismatched sending domain, a third-party bulk mailer return-path, extreme psychological pressure tactics, and an obfuscated malicious URL — all hallmarks of a professionally constructed phishing campaign.

### Recommendations for Future Interns

- 1. Deploy Advanced Email Filtering:** Implement brand impersonation checks (e.g. Microsoft Defender for Office 365 Plan 2) to detect display-name spoofing.
- 2. Mandatory Phishing Awareness Training:** Staff should complete quarterly phishing simulations and annual security awareness training.
- 3. Establish a Phishing Report Button:** Deploy a one-click Report Phishing button in email clients to lower the barrier to reporting.
- 4. Enforce MFA Across All Systems:** MFA prevents immediate account takeover even when credentials are stolen.

5. **Implement Zero-Trust Architecture:** Never trust, always verify — especially for requests arriving via email links.
6. **Create a Security Awareness Culture:** Reward phishing reporters. No blame for clicking — only for not reporting it.

---

**This report was prepared by Prasad Sarkate, SOC Analyst & Security Awareness Trainer, for Future Interns on 24 April 2026.**

The findings and recommendations herein are based on forensic analysis of a live phishing email and are intended solely for internal security awareness and training purposes.